

ÉTUDE DE SÉCURITÉ — MÉTHODE EBIOS (ANSSI)

Analyse de risque cyber de l'entreprise Belhome

Identifier les biens critiques, qualifier les risques d'espionnage et proposer un plan de traitement proportionné à une TPE.

Master Data Analytics — OMNES Education

Module Cybersécurité & Big Data

Manel FRIKHA | Ines DAMMAK | Yasmine BOUAZIZ | Milade LAMMARI

Mission, méthode et déroulé de l'étude

Notre mission

M. Belhome a perdu deux appels d'offres dans des conditions « curieuses » et suspecte une fuite.

Notre rôle : ne pas valider une intuition, mais conduire une étude de risque structurée pour objectiver la menace et proposer des mesures réalistes.

Deux hypothèses à éprouver :

H1 — fuite des données commerciales (prix).

H2 — compromission des études techniques.

La méthode : EBIOS (ANSSI)

Démarche officielle en 5 modules — du contexte aux mesures. Adaptée ici en étude générale, premier jalon avant une analyse complète.

Notre déroulé

- 1 · Contexte & biens
- 2 · Événements redoutés
- 3 · Scénarios de menace
- 4 · Risques & traitement
- 5 · Mesures de sécurité

Contexte métier, enjeux et cadrage de l'étude

Le métier

TPE de 9 personnes (6 ingénieurs agréés, PDG, commercial, RAF). Études de structures pour architectes et promoteurs — marché très technique et concurrentiel. Réputation = actif central.

Les enjeux

Responsabilité pénale à vie des signataires : toute altération, même infime, d'une étude peut engager le pénal en cas d'effondrement. Conservation des données sans limite de durée.

Le déclencheur

Deux appels d'offres perdus coup sur coup dans des conditions « curieuses ». Espionnage des prix probable — mais les études techniques pourraient aussi être visées.

Cadrage du projet — ambitieux mais réaliste

PÉRIMÈTRE

Tout le SI de la TPE : postes, serveurs, supports amovibles, locaux et intervenants.

OBJECTIF

Objectiver les 2 risques craints et livrer un plan d'actions proportionné.

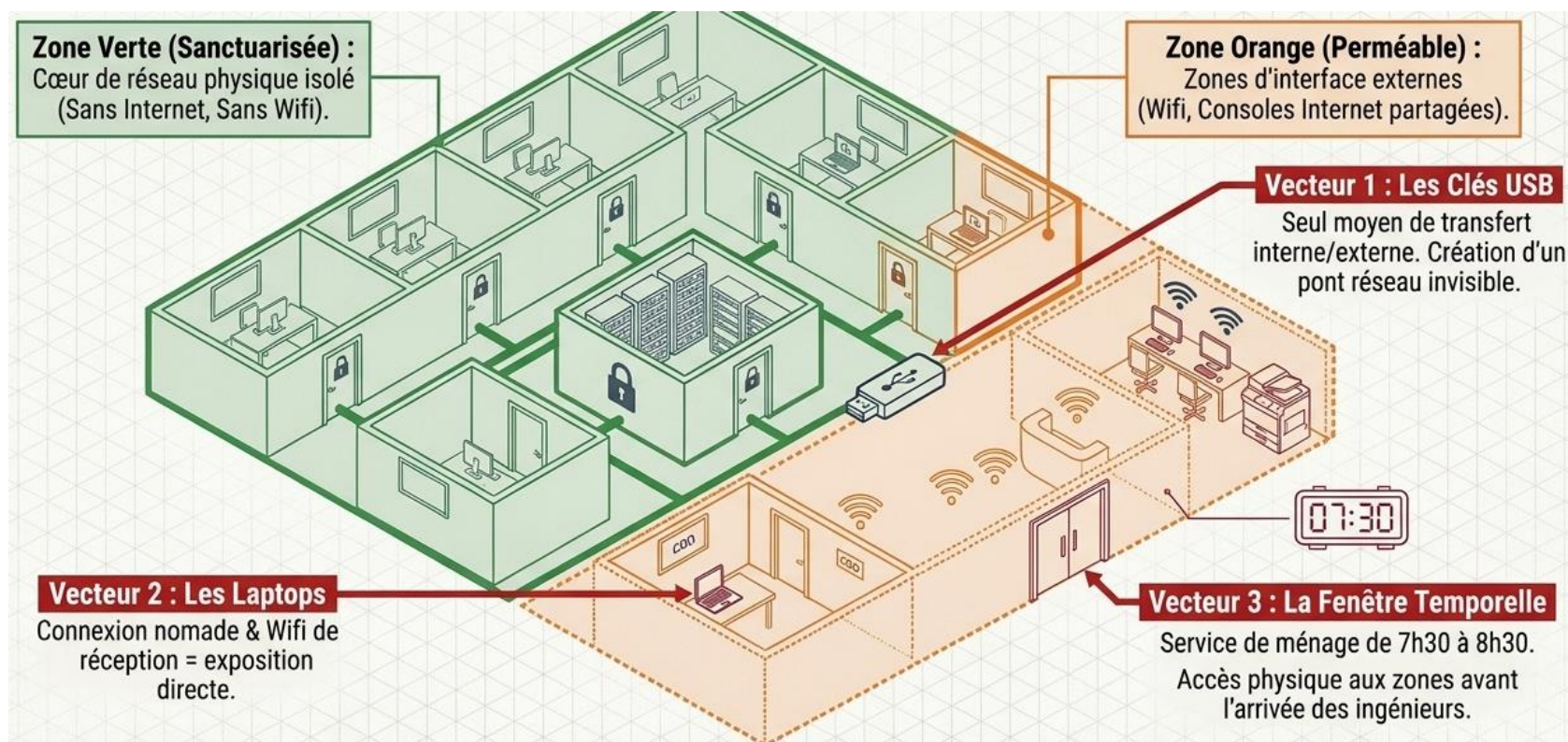
CONTRAINTES

TPE sans RSSI, budget limité, primauté de l'excellence technique.

AMBITION

Étude générale d'abord ; EBIOS complet + audit ensuite.

Deux zones, un pont : où se situe l'exposition réelle



Le constat clé : l'isolement réseau (air-gap) est contourné par les clés USB et l'accès physique. C'est là, et non sur les serveurs, que se joue le risque.

Cartographie des biens essentiels et besoins C / I / D

Bien essentiel	C	I	D	Justification du besoin
BE1 — Études techniques	4	4	3	Espionnage du savoir-faire (C) ; Intégrité = responsabilité pénale et vies humaines (I) ; Conservation illimitée (D).
BE2 — Données commerciales	4	2	2	La fuite des prix entraîne directement la perte d'appels d'offres (cœur du déclencheur).
BE3 — Messages / correspondance	3	2	3	Échanges sensibles internes/externes ; continuité de l'activité.
BE4 — Données admin. & RH	3	2	1	Données nominatives soumises au RGPD.

Échelle : 1 négligeable • 2 limité • 3 fort • 4 critique — C Confidentialité • I Intégrité • D Disponibilité

Biens supports et relations avec les biens essentiels

Par catégorie

Matériel : PC fixes (USB ouverts), 2 portables, 2 consoles, imprimante

Serveurs : logiciels métier, messagerie interne, sauvegarde RAID + miroir

Amovibles : clés USB, DVD

Réseau : LAN câblé isolé ; lien Internet externe

Locaux : bureaux/armoires (clé), salle serveurs (clé)

Humains : ingénieurs, commercial, DAF, PDG, ménage, visiteurs/faux clients

Bien support	BE1 Études	BE2 Comm.	BE3 Msg	BE4 Admin
Serveur sauvegarde + miroir	xx	xx	x	xx
Serveur logiciels métier	xx			
PC fixes ingénieurs	xx		x	x
Portable commercial		xx	xx	
Consoles Internet / imprimante	x	x	xx	x
Clés USB / DVD	xx	x	x	x
Locaux & intervenants	xx	xx	x	xx

Légende : x relation · xx relation persistante. Le ménage et les visiteurs/faux clients sont traités comme biens supports humains.

Les deux événements réellement redoutés par M. Belhome

ER1 — PRIORITÉ 2

Fuite des données commerciales

Bien essentiel : BE2 — Données commerciales

Critères touchés : Confidentialité

Impacts : Perte répétée d'appels d'offres, érosion de la marge et de la position concurrentielle.

Niveau d'impact : 3 / 4 — grave

ER2 — PRIORITÉ 1

Compromission des études techniques

Bien essentiel : BE1 — Études techniques

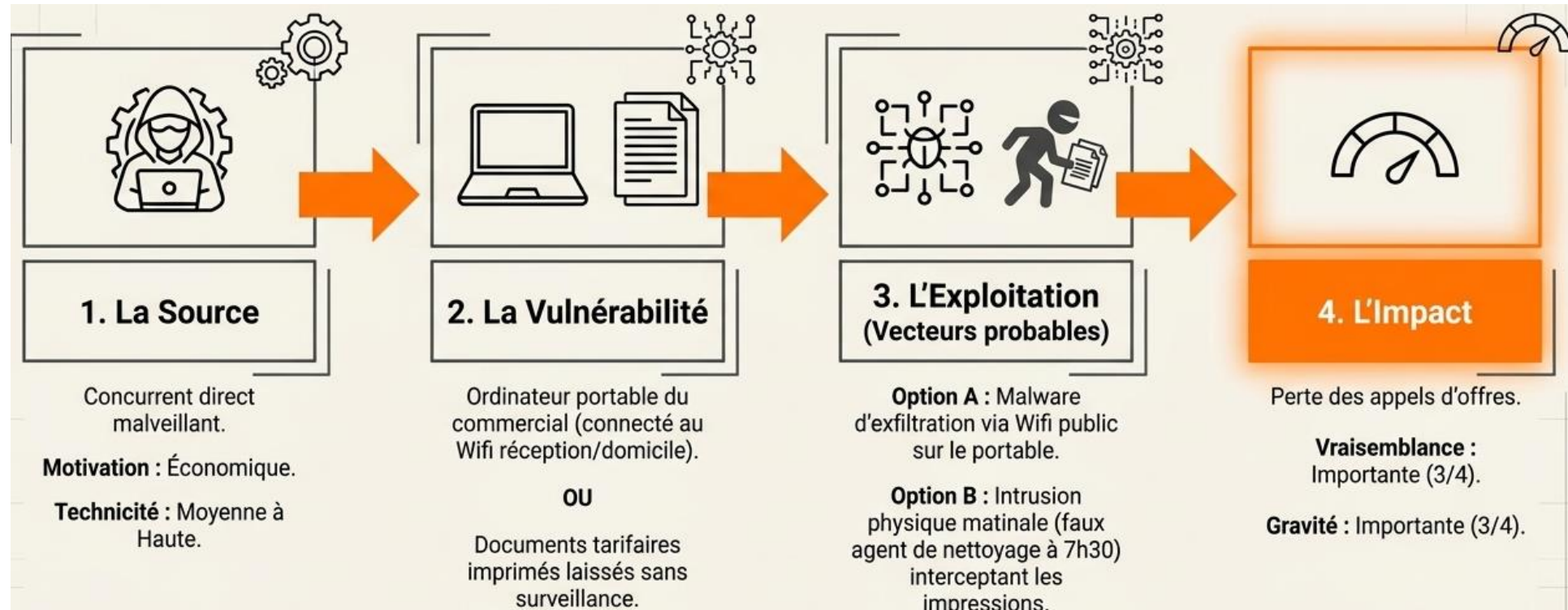
Critères touchés : Confidentialité + Intégrité

Impacts : Perte de savoir-faire et de réputation ; au pire, altération → responsabilité pénale, effondrement, victimes.

Niveau d'impact : 4 / 4 — critique

Scénario R1 — fuite des données commerciales

Source → vulnérabilité → mode opératoire → impact

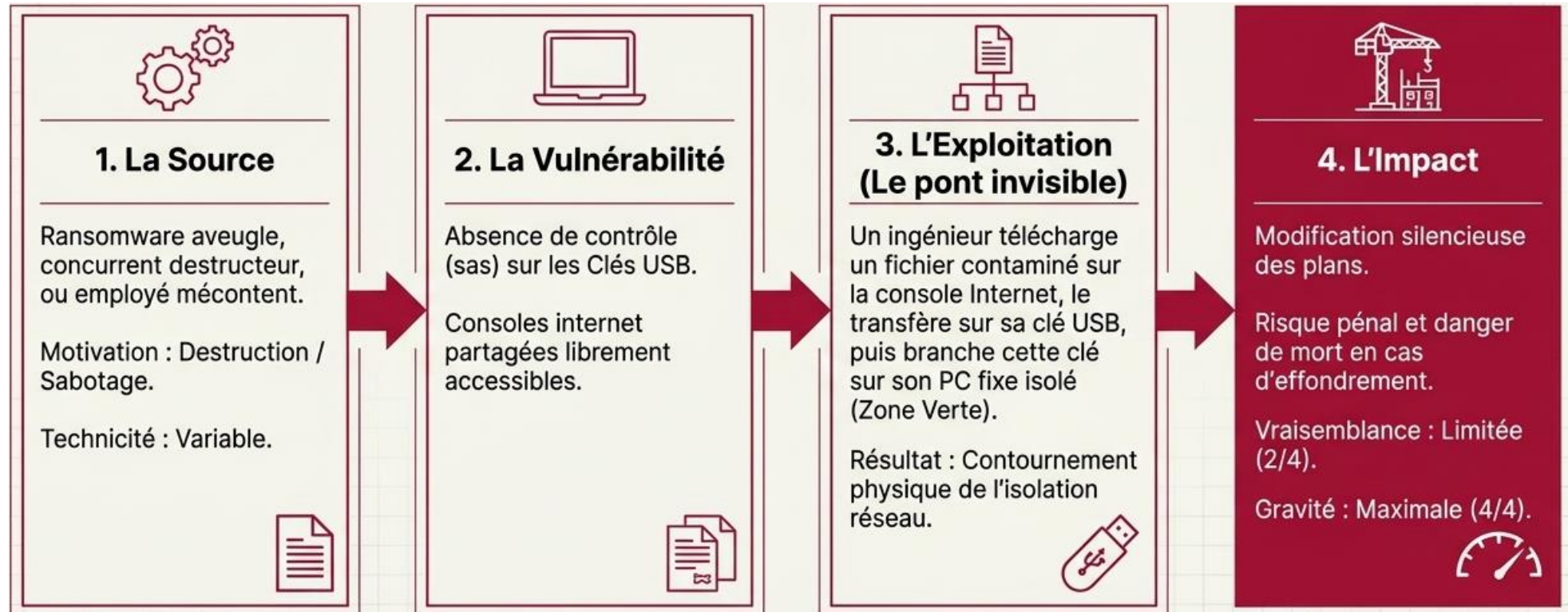


Vraisemblance : 3 / 4 — importante (vecteurs simples, usages courants)

Gravité : 3 / 4 — grave

Scénario R2 — compromission des études

Le « pont invisible » qui franchit l'air-gap



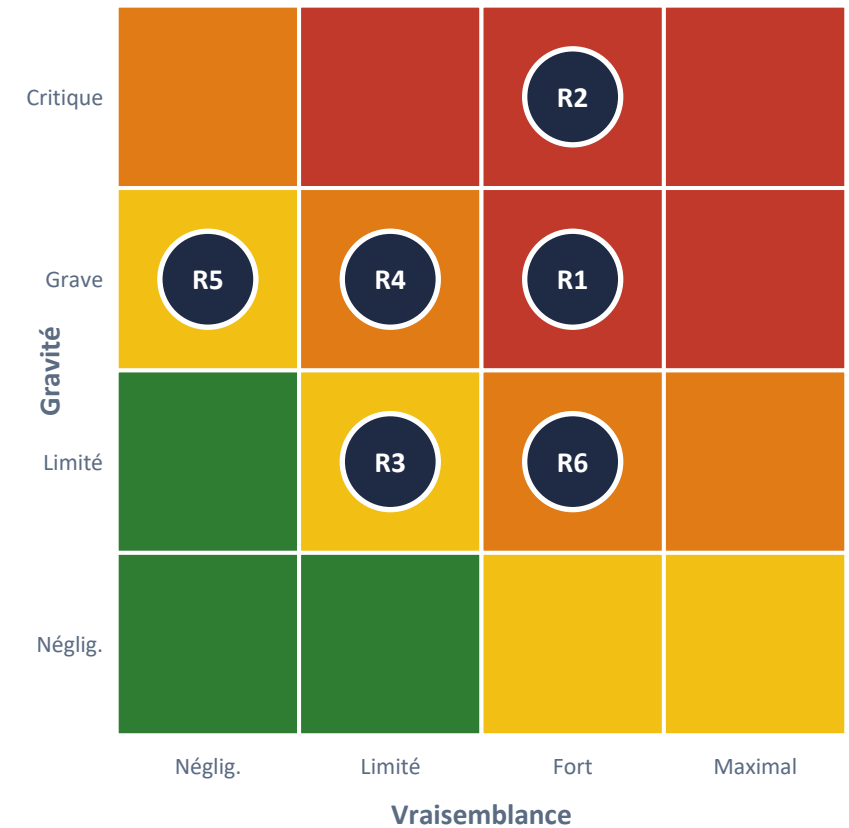
Vraisemblance : 3 / 4 — importante (la clé USB est un usage quotidien, antivirus sporadique)

Gravité : 4 / 4 — critique

Cartographie des risques bruts

#	Risque	Scénario de risque (source → mode opératoire → conséquence)
1	R2 — Espionnage des études	Concurrent/officine : clé USB infectée sur un PC fixe ou accès physique (faux client, ménage) → exfiltration ou altération des études → atteinte pénale, perte de réputation.
2	R1 — Fuite des prix	Concurrent : compromission du portable du commercial ou récupération de propositions via clé USB / impressions non rangées → divulgation des prix → perte répétée d'appels d'offres.
3	R4 — Fuite RGPD	Attaquant ou employé négligent : exfiltration de données nominatives (clients/RH) non chiffrées → sanction CNIL, atteinte à la confiance.
4	R6 — Perte de clé USB	Clé USB non chiffrée contenant une étude, égarée hors de l'armoire → divulgation d'une étude complète à un tiers.
5	R3 — Indispo. messagerie	Panne ou saturation de la messagerie interne → indisponibilité et ralentissement des échanges opérationnels.
6	R5 — Perte par panne	Panne matérielle sur les serveurs → perte de données ; fortement atténuée par le RAID + serveur miroir.

Gravité × Vraisemblance (avant traitement)



Les deux premiers risques sont approfondis (traitement & résiduels) ; les quatre suivants relèvent surtout des bonnes pratiques.

Traitement : combiner les quatre leviers EBIOS

R2 — PRIORITÉ 1 (critique)

Compromission des études

Réduire (levier central) : chiffrement au repos, durcissement de l'accès physique, MAJ antivirus, journalisation des accès.

Éviter (partiel) : condamner les ports USB pour supprimer le vecteur principal.

Transférer (partiel) : assurance cyber pour le résiduel financier.

Accepter : exclu — risque pénal et humain inacceptable.

R1 — PRIORITÉ 2 (fort)

Fuite des données commerciales

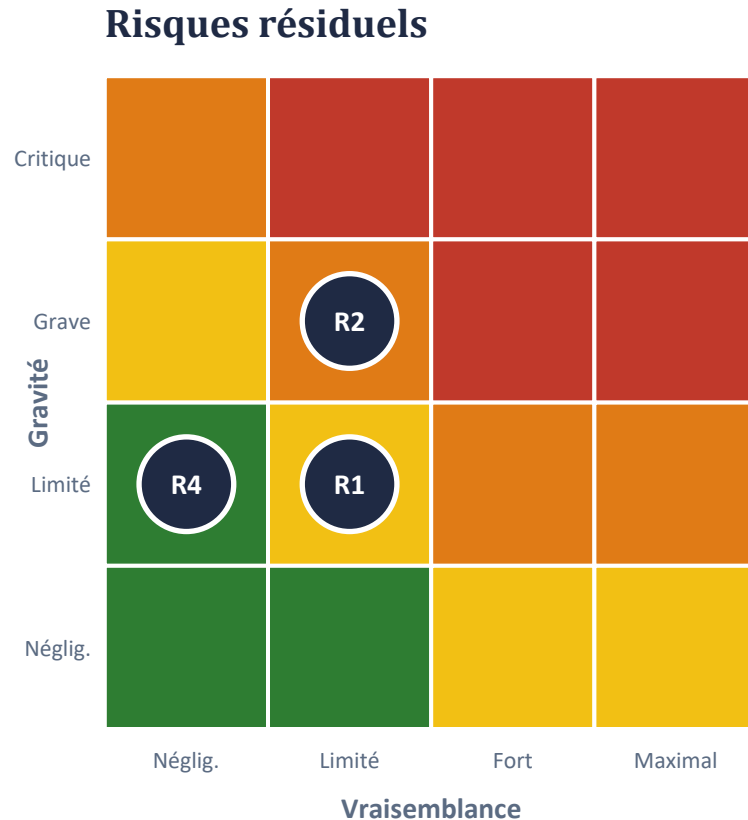
Réduire (levier central) : chiffrement des prix, EDR + VPN sur le portable, cloisonnement, clean printer, sensibilisation.

Transférer (partiel) : assurance cyber pour le préjudice commercial.

Accepter (résiduel) : le risque résiduel (jaune) est acceptable après réduction.

Éviter : non réaliste — le commercial manipule les prix au quotidien.

Risques résiduels après traitement



Caractérisation des résiduels

R2 — Études : 4×3 (critique) → 3×2 (orange). Le chiffrement rend les données volées inexploitable (gravité ↓) ; le verrouillage USB et de l'accès physique abaisse la vraisemblance. Reste surveillé + assurance.

R1 — Prix : 3×3 (fort) → 2×2 (jaune). Le chiffrement et le cloisonnement des prix abaissent la gravité ; le durcissement du portable et le clean printer abaissent la vraisemblance. Acceptable.

R4 — RGPD : 3×2 → 2×1. Chiffrement des données nominatives + registre RGPD.

Principe : on ne supprime jamais le risque, on l'amène à un niveau accepté en connaissance de cause (logique FEROS).

Plan d'actions priorisé pour une TPE

Mesure	Risque	Ligne de défense	Priorité
Condamner les ports USB des postes liés aux études + poste « blanc » avec sas antiviral	R2	Préventive	Haute
Chiffrement au repos des études et des prix ; clés USB nominatives chiffrées	R1•R2	Protectrice	Haute
EDR + VPN + MAJ automatique sur les portables	R1•R2	Préventive	Haute
Sas de réception visiteurs + ménage supervisé + bureaux fermés hors présence	R2	Préventive	Moyenne
Journalisation des accès serveurs (imputabilité) ; tests de restauration RAID	R2•R5	Récupératrice	Moyenne
Sensibilisation : phishing, faux clients, clean desk / clean printer	R1•R2	Préventive	Continue

Deux mesures à fort effet, coût quasi nul

1

MESURE D'ORGANISATION

Politique stricte des supports amovibles

- Clés USB nominatives, chiffrées et journalisées.
- Interdiction des clés personnelles non maîtrisées.
- « Clean desk / clean printer » réellement appliqué et contrôlé.

Effet : coupe le vecteur USB (R2) et les fuites par impression (R1) — coût ≈ 0 .

2

RÉAMÉNAGEMENT DES LOCAUX

Cloisonner les flux et les visiteurs

- Sas de réception : les visiteurs n'entrent plus dans les bureaux.
- Consoles Internet et imprimante isolées en zone surveillée.
- Ménage supervisé / hors des zones sensibles.

Effet : coupe l'accès physique (R2) et l'ingénierie sociale par faux client (R1) — coût faible.

Vivre avec le risque : rigueur, préparation, pragmatisme

Ce que l'étude établit

Belhome cumule un actif à très forte valeur et une surface d'attaque physique (USB, locaux, portables) que l'air-gap ne couvre pas. Les deux risques craints sont réels et prioritaires.

Obstacles & conduite du changement

TPE sans RSSI, primauté de l'excellence technique, autonomie des ingénieurs. Porter le message par la responsabilité pénale et la réputation, jamais par la contrainte.

Limites & suite

Étude générale, sans test d'intrusion. L'effort d'analyse est faible ; le vrai défi est la discipline durable. Étapes : déployer le plan, puis EBIOS complet + audit.

« La sécurité ne sera jamais absolue. La rigueur, la préparation et le pragmatisme sont vos meilleurs atouts. »